

INFORME DE PENTESTING

TryHackMe · trabajo práctico individual · Kali Linux en VirtualBox

Cliente	INSECUR S.A. (escenario académico de la guía).
Contratista	Alessandro Faggionato
DNI	44309510
Usuario TryHackMe	alefaggionato
Email	alefaggionato@gmail.com
Sala de elección	
Branch	Faggionato-Alessandro
Fecha de inicio	07/10/2026
Fecha de cierre	

Resumen ejecutivo

Se completaron las salas Pentesting Fundamentals y Basic Pentesting de TryHackMe mediante un entorno Kali Linux en VirtualBox. En Basic Pentesting se identificaron los servicios expuestos de la máquina asignada, se enumeraron los servicios web y SMB y se accedió por SSH como **kay**. El análisis detectó un listado público de **/development/** y un recurso SMB anónimo que permite leer **staff.txt**. Estos dos hallazgos se desarrollan con sus comandos y evidencias. La IP **10.64.164.65** fue asignada al laboratorio durante la sesión de trabajo.

1. Pre-pentesting

Alcance

El trabajo se realizó en las salas Pentesting Fundamentals y Basic Pentesting de TryHackMe. En Basic Pentesting se trabajó sobre la máquina Web App Test-bard, asignada con la IP temporal 10.64.164.65. Quedaron fuera de alcance los sistemas reales, redes de terceros y objetivos ajenos a los entornos asignados por TryHackMe.

Autorización y reglas de enfrentamiento

La guía autoriza únicamente las actividades en los laboratorios de TryHackMe asignados para la práctica. Prohíbe actuar fuera de ese alcance y aplicar estas técnicas a sistemas reales sin autorización escrita.

La guía indica que las pruebas de autenticación deben realizarse solo si la sala las autoriza y con límites. Las acciones de este trabajo se circunscribieron a la máquina temporal asignada por TryHackMe.

Metodología

Se siguió la secuencia de trabajo de la guía: pre-pentesting, reconocimiento, escaneo, explotación, post-explotación y reporte. Las tareas incluyeron identificación del objetivo, detección de servicios, enumeración web y SMB y acceso SSH. Los comandos y resultados relevantes se relacionan con los hallazgos y las capturas guardadas en el repositorio.

2. Ejecución del trabajo

Pentesting Fundamentals

Se completó la sala Pentesting Fundamentals y se estableció la conexión VPN de TryHackMe. La terminal registró **Initialization Sequence Completed** el 08/10/2026 a las 14:25:30. Evidencia: **evidencias/post/pentesting_fundamentals_completado_vpn.png**.

Basic Pentesting: objetivo y servicios

Se activó la máquina Web App Test-bard con IP 10.64.164.65. Se ejecutó **nmap -sC -sV -oN ~/Downloads/basicpentesting_nmap_inicial.txt 10.64.164.65**. El escaneo identificó 22/tcp SSH (OpenSSH 8.2p1), 80/tcp HTTP (Apache 2.4.41), 139/tcp y 445/tcp SMB (Samba smbd 4).

Evidencias: **evidencias/reconocimiento/basicpentesting_objetivo_10.64.164.65.png** y **evidencias/escaneo/basicpentesting_nmap_10.64.164.65.png**.

Enumeración web

Se ejecutó Gobuster contra el servicio HTTP con 4613 entradas del diccionario. Se identificó **/development/** (301). Al visitar esa ruta se observó un listado de directorio con **dev.txt** y **j.txt**. Evidencias: **evidencias/escaneo/basicpentesting_gobuster_10.64.164.65.png** y **evidencias/reconocimiento/basicpentesting_directorio_development.png**.

Enumeración SMB

Se utilizó smbclient para listar los recursos SMB y acceder sin credenciales al recurso **Anonymous**. Se listó y descargó **staff.txt**, cuyo texto menciona a Jan y está firmado por Kay. Con enum4linux se comprobó que el servidor admite una sesión sin usuario y contraseña. Evidencias en **evidencias/reconocimiento/**: **basicpentesting_recursos_smb.png**, **basicpentesting_anonymous_ls.png**, **basicpentesting_staff_txt.png** y **basicpentesting_enum4linux_U.png**.

Acceso y finalización

Se estableció una sesión SSH como **kay** y se completó la sala Basic Pentesting. Evidencia: **evidencias/post/basic_pentesting_completado.png**.

3. Hallazgos

H-01 · Listado público de /development/

Fase	Reconocimiento y escaneo.
Descripción	La ruta HTTP /development/ muestra un índice de directorio con dev.txt y j.txt.
Componente	Servidor web Apache en 10.64.164.65:80.
Categoría	CWE-548: exposición de información mediante listado de directorios.
CVE	No se atribuye un CVE específico.
Severidad	Media (estimación cualitativa).
Evidencia y herramienta	Gobuster: evidencias/escaneo/basicpentesting_gobuster_10.64.164.65.png. Navegador: evidencias/reconocimiento/basicpentesting_directorio_development.png. Comando completo en bitacora/basic_pentesting_20261008.txt.
Impacto CIA	Confidencialidad: exposición de nombres de archivos y estructura del sitio.
Salvaguarda	Desactivar el listado de directorios y restringir el acceso a archivos de desarrollo.
Riesgo residual	Bajo tras aplicar y verificar el control propuesto.

H-02 · Recurso SMB anónimo con lectura de staff.txt

Fase	Reconocimiento y enumeración.
Descripción	El recurso Anonymous permite listar y descargar staff.txt sin credenciales. Su texto menciona a Jan y Kay.
Componente	Servicio SMB en 10.64.164.65:139/445.
Categoría	CWE-552: archivos o directorios accesibles a partes externas.
CVE	No se atribuye un CVE específico.
Severidad	Media (estimación cualitativa).
Evidencia y herramienta	smbclient: evidencias/reconocimiento/basicpentesting_recursos_smb.png, basicpentesting_anonymous_ls.png y basicpentesting_staff_txt.png. Comandos completos en bitacora/basic_pentesting_20261008.txt.
Impacto CIA	Confidencialidad: lectura no autenticada de información del personal.
Salvaguarda	Requerir autenticación si el acceso público no es necesario; aplicar permisos mínimos.
Riesgo residual	Bajo tras aplicar y verificar los permisos.

4. Resumen y recomendaciones

Crítico	0
Alto	0
Medio	2: H-01 y H-02
Bajo	0
Total	2 hallazgos documentados

Recomendaciones técnicas

- H-02: revisar la necesidad del recurso SMB Anonymous, exigir autenticación y limitar permisos de lectura.
- H-01: desactivar el índice de /development/ y retirar o proteger archivos que no deban ser públicos.
- Repetir las comprobaciones autorizadas tras aplicar los controles para verificar su eficacia.

Recomendaciones administrativas

- Revisar permisos de recursos compartidos y contenido web antes de desplegar cambios.
- Asignar responsables de remediación y conservar evidencia de las verificaciones posteriores.
- Capacitar al equipo para evitar publicar archivos de trabajo o datos del personal en recursos abiertos.

5. Protocolo de contingencia

Escenario: una prueba intensiva o un cambio de configuración durante la remediación interrumpe temporalmente el servicio web o SMB. En un entorno productivo, esto afectaría los procesos que dependan del servicio.

- Activación: detectar indisponibilidad o degradación mediante supervisión y confirmar el servicio afectado.
- Contención, primeros 15 minutos: detener la actividad, conservar registros, aislar el cambio y avisar al responsable técnico.
- Recuperación: restaurar la configuración anterior o un respaldo validado; comprobar disponibilidad y permisos antes de reabrir el servicio.
- Comunicación: informar al equipo técnico, dirección y usuarios afectados según el plan interno.
- Post-mortem: documentar causa, tiempos, acciones y medidas de prevención.

RTO estimado	
RPO estimado	

6. Anexos y declaración ética

Anexo A · Bitácora de comandos

bitacora/basic_pentesting_20261008.txt reúne los comandos documentados de la práctica, sus resultados y las referencias a las evidencias.

Anexo B · Capturas

Las diez capturas se conservan en **evidencias/reconocimiento/**, **evidencias/escaneo/** y **evidencias/post/**. Las referencias concretas constan en cada actividad y hallazgo.

Anexo C · SHA-256 de flags

ID de flag	
SHA-256	

Anexo D · Declaración ética

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante	
Fecha	

Fuentes

Guía de la actividad: [GuiaTryHackMe.pdf](#), incluida en este repositorio. Clasificación de debilidades: MITRE CWE-548 (cwe.mitre.org/data/definitions/548.html) y MITRE CWE-552 (cwe.mitre.org/data/definitions/552.html).